

情報セキュリティ関連規程

情シ-01-00

制定 令和7年10月1日

改訂 回 令和 年 月 日

第1章 総 則

第1節 規程の適用範囲

第1条 (目的と適用範囲)

第1項 目的

1. 本規程は中星工業株式会社の企業活動に於いて実施する情報セキュリティ対策の方針及び行動指針を定めるものである。
2. 別途定められる就業規則等会社組織全体のルールに準じどのような情報資産をどのような脅威からどのように守るのか「基本的な考え方」「情報セキュリティ確保に必要な体制、運用規程、基本方針、対策基準」を明確にすることを目的とする。

第2項 適用範囲

1. この規程は中星工業株式会社の於ける業務で発生する全ての情報に対して適用される。
2. 中星工業株式会社内で別途定められている全ての規程類に適用される。
3. 本規程、別途定められている規程で同様の規程があり、本規程の記載内容との齟齬が認められる場合、適用時の条件の記載が無い限り、本規程記載の内容が優先される。

第2章 情報セキュリティ管理の原則

第1節 組織

第2条 (組織的対策)

第1項 情報セキュリティのための組織

情報セキュリティ対策を推進するための組織として、情報セキュリティ委員会を設置する。情報セキュリティ委員会は以下の構成とし、情報セキュリティ対策状況の把握、情報セキュリティ対策に関する指針の策定・見直し、情報セキュリティ対策に関する情報の共有を実施する

第2項 情報セキュリティ委員会に設定する役職と役割

情報セキュリティ委員会の推進に当たり、以降記載の役職を定めそれぞれ役割を定める。

第3項 役職と役割

1. 情報セキュリティ責任者

情報セキュリティに関する責任者。情報セキュリティ対策などの決定権限を有するとともに、全責任を負う。

2. 情報セキュリティ部門責任者

各部門における情報セキュリティの運用管理責任者。各部門における情報セキュリティ対策の実施などの責任を負う。

3. 情報システム管理者

情報セキュリティ対策のためのシステム管理を行う。

4. 教育責任者

情報セキュリティ対策を推進するために従業員への教育を企画・実施する。

5. IT 管理者

社内で設置されている情報システム部門に於いて専門知識を有する当該部門の管理職又は監督職(係長以上)が当たる。

※第28期8月時点での情報部門はDX推進係を差す

6. インシデント対応責任者

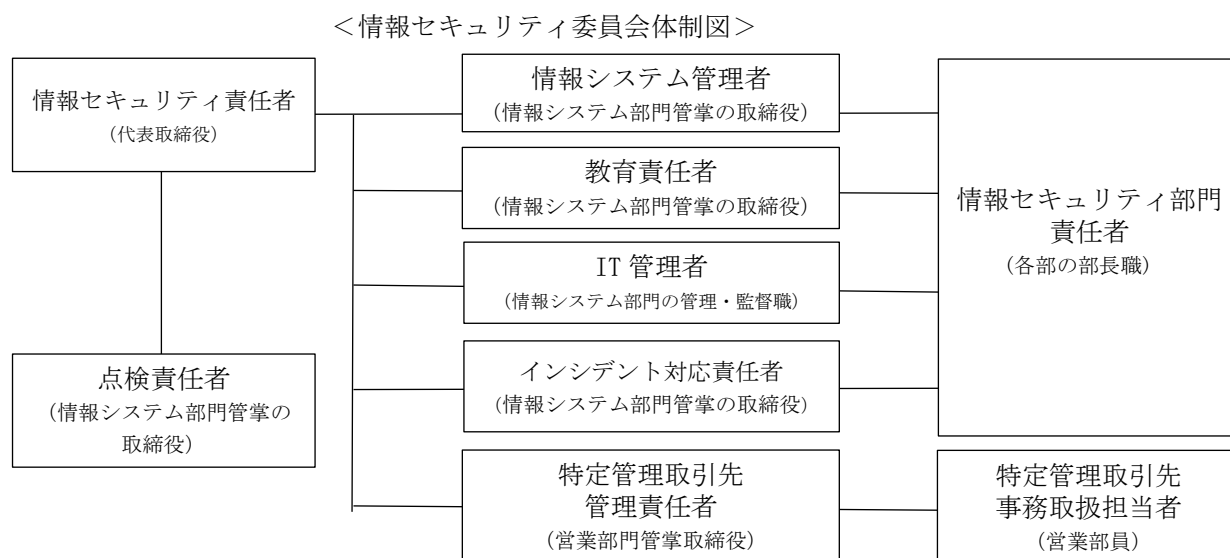
事故の影響を判断し、対応について意思決定する。

7. 点検責任者

情報セキュリティ対策が適切に実施されているか情報セキュリティ関連規程(以降「本規程」と記載)を基準として検証または評価し、助言を行う。

8. 特定管理取引先管理責任者・事務取扱担当者

「防衛」「航空宇宙」「半導体含む電子機器」に関わる製品を取り扱う特に高いセキュリティ対策を必要とする取引先を管理する。当該取引先は別紙・特定管理取引先管理台帳に記載されている



f 第 4 項 担当責任者の原則

前項の役割の内、以下に記載する各責任者においては原則、以下の管掌取締役が担うものとする。

情報システム部門管掌取締役：

情報システム管理者、教育責任者、インシデント対応責任者、点検管理者

営業部門管掌取締役：

特定管理取引先管理責任者

第 5 項 裁量権の移譲

情報セキュリティ委員会を構成する各役割の責任者について、本来その役割を担う管掌取締役の判断より任意の従業員（部長職以上が望ましい）に当該の役割及びその役割を執行するに必要な裁量権を移譲できる。ただし、最終的な責任は管掌する取締役が追うものとする。

第 6 項 職務の分離

情報セキュリティ委員会にて遂行する業務は基本担当者（又は情報セキュリティ部門責任者）が事務処理を含む直接作業に従事し、その上位となる各役割の責任者がこれを承認する。可能な限り実務作業者と承認者が同一とならないようにする。

第 7 項 情報セキュリティ取組みの点検

点検責任者は、本規程及びその他関連規程の実施状況、実務との齟齬について、チェックリスト（別紙情報資産管理台帳、委託先情報セキュリティ対策状況確認リスト等）を用いて 6 月に点検を行い、点検結果を情報セキュリティ委員会に報告する。情報セキュリティ委員会は、報告に基づき、以下の点を考慮し、必要に応じて改善計画を立案する。

- ・本規程が有効に実施されていない場合は、その原因の特定と改善

- ・本規程に定められたルールが、新たな脅威に対する対策として有効でない場合は、本規程の改訂

- ・本規程に定められたルールが、関連法令や取引先の情報セキュリティに対する要求を満たしていない場合は、本規程の改訂

第8項 情報セキュリティに関する情報共有

情報セキュリティ責任者は、新たな脅威及び脆弱性に関する警戒情報及び個人情報の保護に関する情報を専門機関等から適時に入手し、委員会で共有する。

第9項 特定管理取引先の取り扱い

1. 特定管理取引先管理台帳に記載された特定管理取引先に関する情報セキュリティの取り扱いについては本規程記載の中星工業規程のセキュリティ基準に準じて管理する他、当該取引先より特に指定されたセキュリティ基準がある場合にはそれら規程に関しても遵守する。また、特定管理取引先より要請のあった場合には当該企業より提供されたあらゆる情報の管理状況について特定管理取引先管理責任者の責任において公開、提示するものとする。

2. 特定管理取引先管理責任者及び事務取扱担当者は特定管理取引先管理責任者の指示のもと、各管理取引先の指定するセキュリティ基準及び情報の取り扱いについて適切な教育を受けなければならない。また、その教育は中星工業社内にて実施される従業員向け情報セキュリティ教育受講をもって振り替えることができる。

<専門機関>

- ・独立行政法人情報処理推進機構（略称：IPA）

[情報セキュリティ]

<https://www.ipa.go.jp/security/>

[ここからセキュリティ]

<https://www.ipa.go.jp/security/kokokara/>

- ・JVN（Japan Vulnerability Notes）

<https://jvn.jp/index.html>

- ・一般社団法人 JPCERT コーディネーションセンター（略称：JPCERT/CC）

<https://www.jpcert.or.jp/>

第3条（人的対策）

第1項 雇用条件

従業員を雇用する際には秘密保持契約を締結する。

第2項 従業員の責務

従業員は、以下を順守する。

- ・従業員は、当社が営業秘密として管理する情報及びその複製物の一切を許可されていない組織、人に提供してはならない。
- ・就業時間内に作成された調査結果や帳票類を含む資料の著作権は全て会社に帰属するため退職時に会社の許可無く、作成者自身であってもそれらを私物としてメール添付や外部記憶媒体の利用の他いかなる方法によっても社外に持ち出す事はできない。
- ・従業員は、当社の情報セキュリティ方針及び関連規程を遵守する。違反時の懲戒については、就業規則に準じる。

※当社が営業秘密として管理する情報とは、「情報資産管理台帳」の機密性評価値が1以上のものをいう

第3項 雇用の終了

- ・従業員は、在職中に交付された業務に関連する資料、個人情報、顧客・取引先から当社が交付を受けた資料又はそれらの複製物の一切を退職時に返還する。
- ・特定管理取引先に関わる一切のデータについては完全に返却されていることを特定管理取引先管理責任者の確認を最終出社期日の7日前までに受けるものとする。
- ・従業員は、在職中に知り得た当社の営業秘密もしくは業務遂行上知り得た技術的機密を利用して、競合的あるいは競業的行為を行ってはならない。

第4項 情報セキュリティ教育

教育責任者は、以下の点を考慮し、情報セキュリティに関する教育計画を年度単位で立案する。

対象者：未受講社員（新卒新入社員、中途採用社員）及び管理職

テーマ：以下は必須とする。

- ・本規程の説明（入社時、就業時）
- ・最新の脅威に対する注意喚起（随時）
- ・関連法令の理解（関連法令の施行時）
- ・個人情報の取り扱いに関する留意事項
- ・マルウェア、フィッシングメール対策等一般的なセキュリティ対策（年1回以上を想定）

第2節 情報管理

第4条 (情報資産管理)

第1項 情報資産の管理

1. 情報資産の特定と機密性の評価

当社事業に必要で価値がある情報及び個人情報（以下「情報資産」という）を特定し、「情報資産管理台帳」に記載する。情報資産の機密性は、以下の基準に従って評価する。

機密性2：極秘	・法律で安全管理が義務付けられている ・守秘義務の対象として指定されている ・限定提供データ（一定の条件を満たす特定の外部者に提供することを目的とする情報）として指定されている ・営業秘密（秘密として管理されているもの）として指定されている ・漏えいすると取引先や顧客に大きな影響がある
機密性1：社外秘	漏えいすると事業に大きな影響がある
機密性0：公開	漏えいしても事業にほとんど影響はない

2. 情報資産の分類の表示

情報資産の機密性は以下の方法で表示する。

- ・電子データ：保存先サーバーのフォルダー名に表示
- ・書類：保管先キャビネット、ファイル、バインダーに表示

表示が困難な場合は、「情報資産管理台帳」に機密性評価値を表示する。

3. 情報資産の管理責任者

情報資産の取り扱いに関する情報セキュリティの運用管理責任者は、当該情報資産を利用する部門長とする。

4. 情報資産の利用者

情報資産の利用者の範囲は、「情報資産管理台帳」の利用者範囲欄に示された部門に従事する従業員とする。

第2項 (情報資産の社外持ち出し)

情報資産を社外に持ち出す場合には、以下を実施する。

- ・社外秘の場合は所属部門長の許可を得る。
- ・極秘の場合は代表取締役の許可を得る。

- ・情報資産に対して社外からのアクセスが必要な場合には、アクセスに際して ID・パスワードの入力が必要なクラウド環境サーバーから参照する
- ・スマートフォン、タブレット、USB メモリ、HDD 等の物理的電子媒体に保存して持ち出し
 する場合は、当該部門の情報セキュリティ部門責任者の許可を得た上で不要データは
 全てデータ消去専用ソフトウェア
 で消去し、持ち出すデータを暗号化する。
- ・USB メモリ等の小型電子媒体は、識別可能なタグを付ける。
- ・携行中は常に監視可能な距離を保つ。
- ・屋外でネットワークへ接続して極秘又は社外秘の情報資産を送受信する場合は、会社から
 貸与されたスマートフォンによるテザリングにて接続する。
- ・社内の情報資産にアクセスする必要がある際に FreeWifi 等の不特定多数が接続可能な
 環境には接続しない。

第 3 項（媒体の処分）

1. 媒体の廃棄

社外秘又は極秘の情報資産を廃棄する場合は以下の処分を行う。

書類・フィルム	溶解、焼却、細断のいずれかを実施
USB メモリ・HDD・ CD 等(全ての光学ディスク)	破壊・完全消去 ※OS による削除・クイックフォーマットは不可

2. 媒体の再利用

極秘又は社外秘の情報資産を保存した媒体を再利用する場合は、以下の処分を行う。

書類	裏紙再利用禁止(溶解、焼却、細断のいずれかを実施)
USB メモリ・HDD・CD-RW デ ィスク・DVD-RW ディスク	完全消去後再利用 ※OS による削除・クイックフォーマットは不可
CD-R・DVD-R 他	再利用不可(全ての WriteOnce 光学ディスクが対象)

第 4 項（バックアップ）

1. バックアップ取得対象

中星工業株式会社で運用するシステムは原則クラウド環境にて構築する。データ破損を想定し
 たバックアップは AzureCloud 上の仮想サーバーで稼働するシステムデータ、Microsoft365 にて
 運用する個人の Onedrive ストレージに保存されたデータ及び SharePoint サーバー内に保存さ
 れたデータをバックアップの対象とする。とする。

2. データ破損時の対応

マルウェア、ウィルス等により任意のデータに破損が認められた場合、速やかに情報システム管
 理者に報告し、併せて IT 管理者に破損したデータ復旧に必要な作業についての指示を受ける。

また、マルウェア、ウィルス以外の原因とする利用者にとって不本意なデータ喪失(削除、改ざん等)の復旧に際し社内業務システムで利用されているすべてのデータ及び社内業務システムの運用に影響が無いと IT 管理者が認めた場合にはデータ復旧作業を必須としない。

3. クラウド環境で運用できないシステムバックアップ

非クラウド環境にて情報資産の保存、非クラウド環境にて稼働するシステム導入をした場合には当事者又は導入した部門の情報セキュリティ部門責任者の管理責任においてバックアップの計画及び実施を行うものとする。

第 4 項 (特定管理取引先情報の取り扱い)

1. 特定管理取引先に関する情報の取扱いについて各特定管理取引先より指示された管理事項が本規程の内容で対応できない場合、各特定管理取引先より指示された管理方法を遵守する。
2. 特定管理取引先に関する情報の取り扱いは特定管理取引先管理責任者の指示の下、特定管理取引先事務取扱担当者によって適切な方法をもって管理・運用される。
3. 特定管理取引先の情報には各特定管理取引先から提供されるあらゆる電子的情報の他、図面を含む書面、USB メモリ、CD、DVD 等の物理的媒体も含まれる。
4. 電子的、物理的を問わず特定管理取引先より提供された全ての情報は本規程又は各特定管理取引先より指示された方法にて特定管理取引先管理責任者及び事務取扱担当者の責任下にて厳重に管理する。
5. 特定管理取引先より提供された情報がその情報を必要とする業務が完了すると共に各特定管理取引先担当者の指示に従い、返却、削除又は印刷・記録された媒体の物理的破壊をもって速やかに処分する。
6. 特定管理取引先から提供されるシステムへのアクセスアカウント・権限は特定管理取引先管理責任者の承認した対象者にのみ利用を許可及び権限の付与が認められる。

第 5 条 (アクセス制御及び認証)

第 1 項 アクセス制御方針

社外秘又は極秘の情報資産を扱う情報システム又はサービスに対するアクセス制御は以下の方針に基づいて運用する。

- ・「情報資産管理台帳」の利用者範囲に基づき、利用者の業務・職務に応じた必要最低限のアクセス権を付与する。
- ・特定の情報資産へのアクセス権が、同一人物に集中することで発生し得る不正行為等を考慮し、複数名に分散してアクセス権を付与する。
- ・特定管理取引先システムにアクセスする為の権限は特定管理取引先管理責任者の管理の下、業務上利用が認められた者に対してのみ付与される。

第2項 利用者の認証

社外秘又は極秘の情報資産を扱う社内情報システムは、以下の方針に基づいて利用者の認証を行う。

- ・利用者の認証に用いるアカウントは、利用者1名につき1つを発行する。
- ・複数の利用者が共有するアカウントの発行を奨励しない。
- ・複数利用者が共有するアカウントは当該情報セキュリティ部門責任者の許可により、発行するが当該アカウントを利用した不正が発覚した場合、そこから発生した全ての責は共有アカウント発行を許可した当該情報セキュリティ部門責任者が負うものとする。

第3項 利用者アカウントの登録

利用者の認証に用いるアカウントは、代表取締役又は情報セキュリティ責任者の承認・指示の元、情報システム部門担当者によって登録される。

第4項 利用者アカウントの管理

利用者の認証に用いるアカウントが不要になった場合、情報セキュリティ部門責任者は、当該アカウントの削除又は無効化を、当該アカウントが不要になる日の翌日までに情報システム部門に依頼する。

第5項 パスワードの設定

利用者の認証に用いるパスワードは、以下に注意して設定する。パスワードの設定条件は、以下の条件を参照のこと。

- ・8文字以上である
- ・英小文字、英大文字、数字の3種が用いられている
- ・Microsoft Entra ログイン用パスワード(PC ログイン時のパスワード)は各自の責任において90日を目安に変更する

第6項 従業員以外の者に対する利用者アカウントの発行

当社の従業員以外の者にアカウントを発行する場合は、代表取締役又は情報セキュリティ責任者の承認を得たうえで、秘密保持契約を締結する。

第7項 端末のタイムアウト機能

社外秘又は極秘の情報資産を扱う情報システムの端末もしくは情報機器を、アカウントを付与していない者が接触可能な場所に設置する場合は、接続時間制限やタイムアウト等機能を利用する。

第8項 システム管理者アカウント権限の制限

ドメインユーザー及びメールアカウント等、個別アカウントの利用に際し定期的に費用発生するアカウントを登録できる管理者権限は情報システム部門に所属する従業員のみが付与される。

第6条 (物理的対策)

第1項 セキュリティ領域の設定

1. セキュリティ領域の設定

当社内で扱う情報資産の重要度に応じて社内の領域を区分する。区分した領域内では以下を実施する。

レベル1 領域	本社受付・応接スペース・打合せ室・倉庫
利用者	従業員、社外関係者、部外者が立ち入り可
施錠	最終退室者による施錠
設置可能情報機器	ディスプレイ、プロジェクター、ホワイトボード
制限事項	未使用時に社外秘又は極秘の情報資産の放置禁止
部外者管理	従業員の許可を受けて入室可能
火災対策	火災検知器、消火器設置

レベル2 領域	本社執務室・社長室・書庫・工場・営業所
利用者	従業員以外の入室は従業員の許可又はエスコートが必要
施錠	最終退室者による施錠及び警備会社への通報装置作動
設置可能情報機器	ディスプレイ、プロジェクター、ホワイトボード、パソコン、複合機、電話機
制限事項	情報機器・設備の無断操作禁止・無断持出し禁止
部外者管理	主管部門長の許可を受けて入室可能
火災対策	スプリンクラー、消火器設置

レベル3 領域	サーバールーム
利用者	あらかじめ許可された者
施錠	常時施錠
設置可能情報機器	サーバー、ルーター等のネットワーク機器、各種在庫 IT 機器・設備
制限事項	情報機器・設備の無断操作禁止・無断持出し禁止 スマートフォン、USB メモリ、HDD、CD-R、デジタルカメラその他の情報記憶媒体の無断持込み禁止

部外者管理	保守・点検時等に登録者のエスコート付で入室可能
-------	-------------------------

2. セキュリティ領域内注意事項

セキュリティ領域では区分にかかわらず以下の点に注意する。

- ・複合機、プリンタに原稿、印刷物を放置しない。
- ・FAX 送信時には誤送信防止のため宛先を複数回確認する。
- ・ホワイトボードは利用後に消去する。
- ・室内での撮影、録音は禁止する。業務上必要な場合は、情報セキュリティ部門責任者の許可を得ること。
- ・応接室、会議室内及びエレベータ内では会話の盗み聞きを防止するよう配慮する。
- ・外線受話時の際に相手が不審な場合は、従業員の個人情報を伝えてはならない。
- ・部外者を見かけた場合は用件を確認する。
- ・書面等、情報の管理において暗号化できない媒体については各情報セキュリティ部門責任者の管理の下、適切な保管方法にて管理される。また、暗号化できない媒体を外部に送付する場合には「書留郵便」等の追跡可能な方法を用いる。

3. 搬入物の受け渡し

郵便物及び宅配便の受取り・受け渡しは、以下を介して行う。

< 本社 >

- ・郵便物：本社施錠ポスト/書留便の場合は総務部
- ・宅配便：本社受付エリア

第 3 章 情報機器管理

第 1 節 情報機器利用範囲

第 7 条 (IT 機器利用)

第 1 項 ソフトウェアの利用

業務に利用するパソコンには、PC 貸与時に当社の標準ソフトウェアを導入する。当社の標準ソフトウェア以外のソフトウェアを導入する場合は、情報システム管理者の許可を得たうえで導入する。

第 2 項 ソフトウェアの利用制限

情報システム管理者は、利用者の業務に不要な機能をあらかじめ取除いて提供する。従業員は、業務に不要なシステムユーティリティやインストールされているソフトウェアを利用しない。

<利用を禁止するソフトウェア>

- ・インターネット上で、不特定多数のコンピュータ間でファイルをやりとりできるソフトウェア（ファイル共有ソフト）。
- ・不審なベンダーが提供するソフトウェア。
- ・正規ライセンスを取得していないソフトウェア。

第3項 ソフトウェアのアップデート

従業員は、業務で使用するソフトウェアを最新の状態で利用する。

第4項 ウイルス対策ソフトウェアの利用

1. ウイルス検知

従業員は、以下の方法でウイルス検知を行う。

- ・ネットワーク経由で入手するファイルは、自動検知機能を有効にしてウイルス検知を実施する。
- ・電子媒体を用いてファイルの受け渡しを行う場合は、媒体内のファイルにウイルス検知を実施する。

2. ウイルス対策ソフト定義ファイルの更新

従業員は、パソコン・スマートフォン・タブレットに導入したウイルス対策ソフトウェアの定義ファイルを随時更新する。持ち出し用ノートパソコンは利用時に定義ファイルの更新を確認する。

3. 社外機器の LAN 接続

1. 中星工業内で管理するパソコン及びサーバー以外の機器を社内 LAN に接続することを禁止する。業務上必要な場合は、情報システム管理者の許可を得たうえで、当該機器にインストールされているウイルス対策ソフトの定義ファイルを最新版に更新し、当該機器のフルスキャンを実行し、ウイルスが検知されないことを確認してから接続する。

2. 許可された機器であっても社内ネットワークに接続する場合には有線 LAN による接続を行う。GuestWifi 以外の無線 LAN 環境への社外機器接続は一切認めない。

3. 無許可で接続された機器を原因として社内のネットワーク、PC をはじめとするいかなる設備に対して発生した不具合、障害について接続した IT 機器の所有者に対して会社から損害賠償請求することがある。

第5項 社外機器の利用に際しての所有者管理責任

1. 業務遂行において使用される機器(パソコン、タブレット、スマートフォン等)は原則会社より貸与された機器を利用する。

- ・会社より貸与された機器に対しての入力補助機器(キーボード、マウス、液晶を使用したものを含むペンタブレット、10 キー、スタイラスペン)の私物利用には特に制限を設けない。
- ・上記入力補助機器について会社貸与以外の特定個人が利用することを目的とした機器の購入に際し、会社経費での購入はこれを認めない。
- ・情報システム管理者及び情報システム部門責任者の了承を得た場合、社外(私物)機器の業務利用を認めることがある。
- ・許可された私物機器を業務に用いる場合、当該機器に対してのウイルス対策ソフトの運用等セキュリティ対策は所有者の責任をもって行われる。
- ・私物機器の利用に際し、会社経費で購入したいかなるソフトウェアのインストール、会社経費を用いての機能拡張のための機器購入についてこれらを認めない。
- ・私物機器に対しての会社経費を用いたソフトウェア又はハードウェアの購入において情報セキュリティ部門責任者の承認または指示による検証に用いる場合これを認めることがある。
- ・情報セキュリティ部門責任者承認又は指示により購入した私物機器での利用を目的としたソフトウェア又はハードウェアについて当初目的を完遂(検証完了)した時点で当該機器の所有者の責任においてインストール済ソフトウェアの削除又は追加したハードウェア機器の返却を行わなければならない。
- ・会社の業務遂行において私物機器を用いて発生した場合であっても私物機器のソフトウェア的またはハードウェア的に発生したいかなる障害に対して会社は一切保証しない。
- ・私物機器を利用した事を起因とする社内ソフトウェア、ハードウェアで発生した障害を原因として発生した会社の損失について所有者の責任を問われることがある。
- ・私物機器を起因とする障害が発生し所有者の責任が問われた場合、発生した損失について所有者が負担する。ただし情報セキュリティ部門責任者からの指示によりものである場合においてはその限りとしない。
- ・私物機器を起因とする取引業者を含む個人情報、会社の営業秘密の流出が発覚した場合故意、過失を問わず所有者に対して会社は訴訟を含めた損害賠償請求を行うことがある。
- ・私物機器利用により発生したいかなる費用について会社は一切負担しない。私物機器利用自体が情報セキュリティ部門責任者指示による場合には情報セキュリティ部門責任者が当該私物機器の所有者と共に責任を担う。

2. ウイルス対策の啓発

情報システム管理者は、適宜ウイルスに関する情報を収集し、重大な被害を与えるウイルスに対しては、対応策及び対応に必要な修正プログラムを社内に公開及び通知する。従業員は、感染防止策が通知された場合は、速やかに実施完了すること。

3. IT機器の利用

従業員は、業務に利用するパソコン・タブレット・スマートフォンには、ログインパスワードを設定する。利用するときには以下を実行する。

- ・ログインパスワードを他者の目に触れる所に書き記さない。
- ・屋外で利用する場合は、他者が画面を盗み見可能な環境で利用しない。
- ・退社時又は使用しないときには電源を切り、ノートパソコン・タブレット・スマートフォン・USB メモリ、HDD、CD 等の電子媒体は施錠保管する。

第6項 クリアデスク・クリアスクリーン

1. クリアデスク

従業員は、社外秘又は極秘の書類及び電子データを保存したノートパソコン、USB メモリ、HDD、CD 等の持ち運び可能な機器や媒体の扱いについて、以下のようにクリアデスクを徹底する。

- ・利用時以外には机上に放置しない。
- ・離席時に書類を伏せる、引き出しに入れる等する。
- ・退社時又は使用しないときには机の引き出しに保管し、施錠する。

2. クリアスクリーン

従業員は、離席時に以下のいずれかによりパソコンの画面をロックし、クリアスクリーンを徹底する。

- ・スクリーンセーバー起動時間を5分以内に設定する。
- ・スリープ起動時間を基本5分以内に設定する。
- ・離席時に [Windows] キー+ [L] キーを押してコンピュータをロックする。
- ・ログオフ状態ではシステム操作画面は非表示に設定する。退社時又は使用しないときにはパソコンの電源を切る。
- ・スマートフォン・タブレットを外出先で利用する場合は、他者が盗み見できる環境で利用しない。

第7項 インターネットの利用

従業員は、インターネットを利用する際には以下を遵守する。

1. ウェブ閲覧

情報システム管理者は、ウイルス等の悪意のあるソフトウェアに感染するおそれがあると認められる有害ウェブサイトは社内周知して、従業員の閲覧を制限する。従業員は、業務でウェブ閲覧を行う場合は以下に注意する。

- ・ 公序良俗に反するサイトへのアクセスを禁止する。
- ・ 不審なサイトへのアクセス及び社用メールアドレス登録を禁止する。
- ・ 業務上、個人情報(メールアドレス、氏名、所属等)を入力する場合は、通信の暗号化、接続先の実在性等を十分に確認したうえで行う。
- ・ 信頼できるサイトから署名付きのモバイルコードをダウンロードする場合を除き、モバイルコード(クライアントパソコン側で動作するプログラム)を実行しない。

2. オンラインサービス

従業員は、インターネットで提供されているサービスを業務で利用する場合は、情報システム管理者の許可を得る。利用する際には以下に注意する。

<インターネットバンキング・電子決済>

- ・ インターネットバンキングを利用する際には、自分で設定したブックマークや銀行が提供する専用アプリケーションソフトを用いる。
- ・ 電子決済を利用する際には、SSL/TLS による通信暗号化を採用しているサイトを利用する。
- ・ 電子メールに記載されているリンクや、他のウェブサイト等に設置されているリンクは、偽サイトへの誘導である可能性があるためアクセスしない。

<オンラインストレージ>

- ・ 個人契約したオンラインストレージ又は私用メールアドレスがログイン情報を関連づけられたオンラインストレージを会社業務に使用しない。
- ・ メールアドレスの登録が必要な場合は社用メールアドレスを登録する。
- ・ セキュリティポリシーを公表していないサービスの利用は禁止する。
- ・ 不審なベンダーが提供しているサービスの利用を禁止する。

3. SNS の個人利用

- ・ 当社の業務に関わる情報の書き込みは行わない。
- ・ 個人的な SNS アカウントを用いての投稿を起因として会社になんかの不利益をもたらした場合、投稿者に対して会社は訴訟を含む損害賠償請求をすることがある。
- ・ 取引先従業者と SNS 上で私的に交流する場合、双方の立場をわきまえ、社会人として良識の範囲で交流する。
- ・ SNS 用のアプリケーションが提供するセキュリティ設定を行い、アカウントの乗っ取りやなりすましに注意する。
- ・ 使用するパソコン、スマートフォン、タブレット上のデータ、写真、位置情報が、予期せず公開される可能性のあることに注意する。

4. 電子メールの利用

従業員は、業務で電子メールを利用する際には以下を実施する。

<誤送信防止>

特に社外に電子メールを送信する場合、送信先メールアドレスの確認を確実に行う。

<メールアドレス漏えい防止>

同報メール（外部の多数相手に同時に送信するとき）を送信する場合は、宛先（TO）に自分自身のアドレスを入力し、BCC で複数相手のアドレスを指定する。

<傍受による漏えい防止>

社外秘又は極秘の情報資産を送信する場合は、メール本文ではなく添付ファイルに記載して送信する。

<クラウド型メールの利用>

業務でクラウド型メール（Yahoo メール又は Gmail 等）を利用は原則禁止とする。これらの利用を業務上行う必要がある場合には情報システム管理者又は IT 管理者に事前相談及び利用承諾の上、必要な業務大してのみ使用する。

情報システム管理者から許可されたパソコン以外で、メールサーバーからのメールの取り出し及びエクスポートを禁止する。

<禁止事項>

業務に支障をきたす恐れがある使用。

社内機器からの私用電子メールサーバーへの接続。

5. ウイルス感染の防止

標的型攻撃メール等によるウイルス感染を防止するため、以下の内容に複数合致する場合は十分に注意し、添付ファイルを開かない及びリンクを参照するなどしない。受信した場合は、情報システム管理者に報告し、情報システム管理者は社内に注意を促す。

メールのテーマ	①知らない人からのメールだが、メール本文のURL や添付ファイルを開かざるを得ない内容 ・新聞社や出版社からの取材申込や講演依頼 ・就職活動に関する問い合わせや履歴書送付 ・製品やサービスに関する問い合わせ、クレーム ・アンケート調査 ②心当たりのないメールだが、興味をそそられる内容 ・議事録、演説原稿などの内部文書送付
---------	---

	・VIP 訪問に関する情報 ③これまで届いたことがない公的機関からのお知らせ ・情報セキュリティに関する注意喚起 ・インフルエンザ等の感染症流行情報 ・災害情報 ④組織全体への案内 ・人事情報 ・新年度の事業方針 ・資料の再送、差替え ⑤心当たりのない、決裁や配送通知（英文の場合が多い） ・航空券の予約確認 ・荷物の配達通知 ⑥IDやパスワードなどの入力进行要求するメール ・メールボックスの容量オーバーの警告 ・銀行からの登録情報確認
差出人のメールアドレス	①フリーメールアドレスから送信されている ②差出人のメールアドレスとメール本文の署名に記載されたメールアドレスが異なる
メールの本文	①日本語の言い回しが不自然である ②日本語では使用されない漢字（繁体字、簡体字）が使われている ③実在する名称を一部に含むURL が記載されている ④表示されているURL（アンカーテキスト）と実際のリンク先のURLが異なる（HTML メールの場合） ⑤署名の内容が誤っている ・組織名や電話番号が実在しない ・電話番号がFAX 番号として記載されている
添付ファイル	①ファイルが添付されている ②実行形式ファイル(exe/scr/cplなど)が添付されている ③ショートカットファイル(lnkなど)が添付されている ④アイコンが偽装されている ・実行形式ファイルなのに文書ファイルやフォルダーのアイコンとなっている ⑤ファイル拡張子が偽装されている ・二重拡張子となっている ・ファイル拡張子の前に大量の空白文字が挿入されている ・ファイル名にRL04が使用されている

第8項 私物 I T 機器・電子媒体の利用

従業員個人が所有するパソコン、タブレット等の I T 機器及びメモリ、HDD、CD 等の電子媒体を業務利用しないこと。やむを得ない状況、業務上必要な状況が発生した場合には予め情報セキュリティ部門責任者の承認の元、情報セキュリティ責任者に利用目的及び利用範囲を報告の上、利用を行うこと。

私用の携帯電話やスマートフォンを社内 PC に接続してのデータ送受信を禁止する。

1. 利用開始時

利用を開始する前に利用する本人が以下を実行する。

- ・ 情報システム管理者が指定するウイルス対策ソフトウェアをインストールし、定義ファイルを更新する。
- ・ ハードディスク、電子媒体に対してウイルスチェックを行う。
- ・ 業務に支障が出る可能性があるソフトウェアを削除する。
- ・ 当社で契約したサービス以外の Wi-Fi スポットの利用は禁止する。

2. 利用期間中

利用期間中は、利用する I T 機器や電子媒体に以下に該当する機能がある場合には実行する。

- ・ ウイルス対策ソフトウェアの定義ファイルを常に最新版に更新する。
- ・ OS やアプリケーションソフトのアップデートが通知されたら速やかに実施する。
- ・ 社内 LAN へのリモート接続する場合は情報システム管理者の許可を得る。
- ・ 社外から社内 LAN にリモートで接続する場合は以下を遵守する。
 - 情報システム管理者の許可を受け指定された方法で接続する。
 - 画面の盗み見、不正操作等を防ぐよう、適切な環境で行う。
 - 端末機器から離れる場合は、端末機器を停止するか他者が利用できないようにする。
 - リモート接続で利用する端末機器を紛失した場合は、直ちに情報システム管理者に連絡し 指示に従う。
 - 社用メールアドレスで受信した取引業者とやり取りしたメールを従業員個人のアドレスに転送することを禁止する。
 - 社内内で利用したデータを従業員個人のアドレスに送信することを禁止する。
 - 社外秘又は極秘の情報資産の保存を禁止する。
- ・ 以下のアプリケーションソフトのインストールと利用を禁止する。
 - 機器ベンダーの公式な公開場所（App Store、Google Playなど）以外から提供されるもの。
 - 不審なベンダーが提供するもの。
 - 正規ライセンスを取得していない違法なもの。

- ・ 会社で契約したサービス社外の Wi-Fi サービスの利用を禁止する。
- ・ 自宅や屋外で利用する場合は以下を遵守する。
 - 信頼できる通信回線のみを利用する。
 - 機器は原則として勤務時間のみ稼働させる。
- ・ 不審なメールの受信など、情報セキュリティで不安がある場合は情報システム管理者に問い合わせる。

3. 社内での利用

利用期間中に私物の I T 機器や電子媒体を社内に持ち込む場合は、情報システム管理者の許可を得る。社内 LAN への接続する場合は情報システム管理者から許可された範囲のみの利用とする。

充電を除き、社内のパソコンやサーバーへの接続は禁止する。

第 2 節 運用

第 8 条 (IT 基盤運用管理)

第 1 項 管理体制

情報システム管理者は、I T 基盤の運用に当たり情報セキュリティ対策を考慮し製品又はサービスを選択する。I T 基盤の情報セキュリティ対策及び関連仕様は、情報セキュリティ責任者が承認する。

第 2 項 I T 基盤の情報セキュリティ対策

I T 基盤の運用の際には以下の技術的情報セキュリティ対策を考慮すること。

1. サーバー機器の情報セキュリティ要件

I T 基盤で利用するサーバー機器に求める情報セキュリティ要件は、情報システム管理者が決定する。新規にサーバー設備が必要な場合には原則 Azure クラウド環境での仮想サーバー環境を手配し、物理的な機器を導入しない。

2. サーバー機器に導入するソフトウェア

I T 基盤で利用するサーバー機器に導入するソフトウェアは、情報システム管理者が標準ソフトウェアを選定する。新規にソフトウェアを導入する場合は、情報システム管理者及び IT 管理者の許可を得て導入する。

3. ネットワーク機器の情報セキュリティ要件

I T基盤で利用するネットワーク機器に求める情報セキュリティ要件は、情報システム管理者が決定する。新規にネットワーク機器を導入する場合は、情報セキュリティ要件を満たす製品を選択し、情報システム管理者の許可を得て導入する。

第3項 I T基盤の運用

情報システム管理者は、I T基盤の運用を行う際には以下を実施すること。

- ・情報システム管理者は、機器の管理画面にログインするためのパスワードは初期状態のまま使わず、推測不可能なパスワードを設定して運用する。
- ・情報システム管理者は、通信ログについて以下の確認を定期的に行う。
 - 管理外のインターネット接続がないか
 - 許可なく接続された機器や無線 LAN 機器はないか
 - 情報システム管理者は業務に不要なウェブサイト閲覧を社内周知して制限する。

第4項 クラウドサービスの導入

I T基盤の一部としてクラウドサービス等の外部サービスを導入する場合は、情報システム管理者がサービスプロバイダの情報セキュリティ対策をあらかじめ評価したうえで選定する。新規クラウドサービス等の外部サービスを導入する場合は、情報システム管理者の許可を得て導入する。

第5項 脅威や攻撃に関する情報の収集

情報システム管理者は、最新の脅威や攻撃に関する情報収集を行い、必要に応じて社内で共有する。

第6項 廃棄・返却・譲渡

情報システム管理者は、I T基盤で利用した機器を返却、廃棄、譲渡を行う場合は、内部記憶媒体の破壊又は専用ツールによりデータを完全に消去し、情報セキュリティ責任者の承認を得たうえ返却、廃棄、譲渡を行う。内部記憶媒体の破壊又はデータの完全消去を、外部に委託する場合は、破壊又はデータの完全消去を実行したことの証明書を取得する。

第7項 I T基盤標準

I T基盤で利用する機器及びソフトウェアの情報セキュリティ要件と、それに基づく当社標準を以下とする。

1. サーバー機器情報セキュリティ要件

対象システム	セキュリティ要件	利用技術・製品
ファイルサーバー	利用者認証機能	Microsoft OneDrive

	セキュリティログ取得機能	Windows
	システムログ取得機能	Windows
	ユーザーアクセスログ取得機能	Skysea

2. I T 基盤標準ソフトウェア

種別	名称	開発・販売元	バージョン
OS	Windows Server	Microsoft	2019 以降
R D B	MSSQL	Microsoft	
	OracleDB	Oracle	
ウイルス対策	ESET インターネットセキュリティ	キャノン IT ソリューションズ	

3. クラウドサービス情報セキュリティ対策評価基準

- ・サービスプロバイダが公表する情報セキュリティ又は個人情報保護への取組方針が、処理しようとする情報資産の重要度に照らして適切であること。
- ・サービス仕様に含まれる情報セキュリティ対策が、処理しようとする情報資産の重要度に照らして適切であること。
- ・情報セキュリティに関する適合性評価制度の認証・認定を取得していること。

<適合性評価制度の種類>

- ISMS 適合性評価制度（ISMS 認証/ISMS クラウドセキュリティ認証）
- クラウド情報セキュリティ監査制度
- プライバシーマーク制度
- PCI DSS（クレジットカード業界セキュリティ基準）
- ASP・SaaS の安全・信頼性に係る情報開示認定制度
- インターネット接続安全安心マーク

第 4 章 情報システム開発

第 1 節 業務システム開発

第 9 条 （システム開発及び保守）

第 1 項 新規システム開発・改修

情報システムの開発・改修を行う際には、実施部門において以下の工程を経て実施する。各工程の完了時に情報システム管理者及び IT 管理者の承認を得る。

- ①対象業務の範囲定義
- ②ハードウェア・ソフトウェア・ネットワーク機能検討

※但し物理サーバーの導入は原則しない

- ③必要なパフォーマンスの検討

- ④情報セキュリティ要件定義
- ⑤バックアップ/障害復旧要件定義
- ⑥情報システム運用要件定義
- ⑦運用体制
- ⑧移行計画立案

第2項 情報システムの開発環境

情報システムの開発及び改修を行う環境は、運用環境とは分離する。新たに情報システムの開発を行った場合や、情報システムの改修を行った場合は、当該情報システムの運用を開始する前に、必要な情報セキュリティ対策が講じられていることを確認し、情報システム管理者及び IT 管理者の承認を得る。

第3項 情報システムの保守

導入後の情報システムの保守については原則開発元又は当該システムを販売したベンダー等外部の組織に委託する。情報システムの保守を、開発元又は外部の組織に委託することができない場合、以下に挙げる事項に留意し、情報システムに既知の脆弱性が存在しない状態で運用する。

- ・開発時に用いたソフトウェアに関する脆弱性が公表された場合には、速やかにその影響が顕在化しないための対策を講じる。
- ・開発時に用いたソフトウェア及びハードウェアの製造者が提供するサポートが終了した場合、他のソフトウェアやハードウェアを用いた再構築又は当該情報システムの利用停止を検討し、情報システム管理者及び IT 管理者の承認を得る。
- ・導入後の情報システムの保守が開発元を含む外部の組織にも自部門所属の従業員に対応できない場合、当該システムを導入検討する選択肢に入れない。特定の取引先からの指示により、導入選択の是非を社内内で決定できないシステム導入に際してのみ情報システム部門が導入に関与することがあるが原則運用部門で対応する。

第4項 情報システムの変更

情報システムのハードウェア又はソフトウェアの変更を行う際には、以下の工程を経て実施する。各工程の完了時に情報システム管理者及び IT 管理者の承認を得る。

- ①現行システムの問題・課題の把握
 - ②システム変更計画立案
 - ③システム変更計画書に基づくシステム設計
 - ④セキュリティ要求と設計の見直し
 - ⑤移行計画立案（移行時、運用時の障害対応をあらかじめ検討する。）
 - ⑥変更後の仕様書、操作手順書、運用手順書等の関連文書の作成
- ※サーバー環境の更新に際しては基本クラウドサーバーでの構築を前提とする

第5項 EUC(End User Computing)の制限

VBA、Java 等のプログラミング言語の利用有無、RPA による開発を問わず特定の担当者のみが管理、保守可能なシステムを構築し、担当者本人以外の社員が関与する業務に用いてはならない。部門の業務フロー上で運用するシステムは原則社外で開発され、障害発生時にはその対応が可能な業者が開発したシステムを運用する。

- ・既存且つ長期的に業務で使用されていた実績があるツールであったとしてもその保守に対して情報システム部門(29期8月現在では情報システム課DX推進係)は対応を行わない。
- ・前項により発生するいかなる業務上の不具合に対して情報システム部門は一切責を負わない。
- ・既存且つ長期的に業務で使用されていた実績があるツールの開発者、保守者の異動、退職等の理由により当該ツールに対しての以後の保守が困難になる場合には予め部門責任者が業務手順の変更等の対策を準備しておく。
- ・開発者不在により業務に不都合が発生する、又はした場合であっても情報システム部門は一切関知しない、またそこから生じたいかなる障害に対しても対応の責を負わない。
- ・EUC によって開発されたツールについて業務上運用することにやむを得ない理由がある場合、部門内にて運用上発生しうる全ての問題を部門内で解決できることが明確な場合に限り、情報セキュリティ管理者がこの使用を認めることがある。
- ・やむを得ない EUC の利用が必要な場合、情報セキュリティ部門責任者管理の下、各利用部門の責任において業務使用 EUC 管理台帳を作成、管理し作成者の退職又は異動に際しては作成者の担当した EUC の引継ぎについても、当該 EUC を必要とする業務に支障無いように実施する。
- ・情報システム部門が中星工業従業員による活用前提で提供しているツール(2025年8月時点ではUnitBase)についてのみ、所属部門の業務改善への活用について従業員が所属帳の許可の下、自由にデータベース追加、管理帳票の作成等の業務に利用して良い。

第6項 従業員による生成 AI の業務利用可能な範囲

1. 利用目的の明確化:生成 AI は、業務効率化、アイデア出し、情報整理、プログラミング補助、翻訳などの生産性向上に資する目的に限り利用を許可する。
※ 機密情報の生成、個人情報の取り扱い、法務・財務に関する最終判断、顧客への直接的な回答など、会社の信用や顧客に影響を及ぼす可能性のある業務には、単独での生成 AI の利用を禁止する。
2. 利用可能なツール:情報システム部門が承認した生成 AI ツールのみ利用を許可する。未承認のツールの利用は禁止する。承認ツールは、情報システム部門がセキュリティ要件、データプライバシー、利用規約などを評価し、安全性を確認した上で決定する。生成 AI ツール利用申請についての詳細は情報システム部門に随時確認する。
※承認済生成 AI:Microsoft 社の Copilot については既に一部で使用中

生成 AI を業務に利用する時の注意点について

3. 情報の正確性の確認:生成 AI が出力する情報は、必ずしも正確ではない可能性があるため、その内容を鵜呑みにせず、事実確認を行う。特に、公開情報でない情報源や、専門性が要求される情報については、複数の情報源でクロスチェックする。
4. 著作権・知的財産権への配慮:生成 AI の利用にあたっては、著作権や知的財産権を侵害しないよう細心の注意を払う。生成 AI が既存の著作物から学習している場合があるため、生成されたコンテンツをそのまま利用する際は、その権利帰属を確認する。生成 AI によって生成されたコンテンツの著作権や知的財産権の帰属については、利用している生成 AI サービスの利用規約を遵守する。
5. 倫理的配慮:差別的表現、偏見、ハラスメントなど、倫理的に問題のある内容を生成しないよう注意する。生成 AI の利用が、社会的な公平性や透明性を損なわないように配慮する。

####生成 AI の業務に利用により発生することが予想できるインシデントの防止について

6. プロンプトインジェクションへの対策:生成 AI への指示（プロンプト）において、機密情報や個人情報を意図的に引き出そうとするプロンプトインジェクションに対し、不適切な応答をしないよう、注意喚起と啓発を行う。重要な情報を取り扱うプロンプトには、機密情報を含まないよう配慮する。
7. 誤情報・不正確な情報の拡散防止:AI が生成した誤情報や不正確な情報が、社内外に拡散することを防ぐため、情報の公開前に必ず人間の目でレビューし、検証を行うプロセスを義務付ける。
8. 過信による判断ミスの防止:生成 AI の能力を過信し、重要な判断を AI 任せにすることを防ぐ。最終的な意思決定は人間が行うことを徹底する。

####生成 AI の業務に利用による情報漏洩防止ルール及びその実施手順について

9. 機密情報・個人情報の入力禁止:会社が保有する機密情報（顧客情報、製品設計情報、未公開の財務情報など）や個人情報（従業員の氏名、連絡先、生年月日など）を生成 AI に入力することを一切禁止する。特に、学習型生成 AI の場合、入力された情報が学習データとして利用され、第三者に流出する可能性があるため、厳重に禁止する。
10. 匿名化・仮名化の徹底:やむを得ず、生成 AI に情報の一部を入力する必要がある場合は、可能な限り匿名化または仮名化を行い、個人や特定の企業が特定できないように加工する。
10. 従業員への継続的な教育:生成 AI の利用に関する情報セキュリティリスクについて、定期的な研修や注意喚起を行い、従業員の情報セキュリティ意識を向上させる。新しいリスクや脆弱性が発見された場合は、速やかに全従業員に周知する

第 2 節 外部委託

第 10 条 （委託管理）

第1項 委託契約の締結

委託契約書には、下記に関する事項を明記する。

- ・当社の社外秘又は極秘の情報資産及び個人情報の守秘義務
- ・再委託についての事項
- ・事故時の責任分担についての事項
- ・委託業務終了時の当社が提供した社外秘又は極秘の情報資産及び個人情報の返却又は廃棄、消去についての事項
- ・情報セキュリティ対策の実施状況に関する監査の方法とその権限
- ・契約内容が遵守されない場合の措置
- ・事故発生時の報告方法
- ・訴訟発生時の係争先裁判所

第2項 委託先の評価

委託開始後には、「委託先情報セキュリティ対策状況確認リスト」により、委託先における情報セキュリティ対策の実施状況について定期的に評価する機会を設ける。委託先における情報セキュリティ対策の実施に関して不備又は変更が認められた場合は、双方協議のうえ、対処を検討し、書面で合意する。

<委託先評価の方法>

- 委託先事業所に訪問して現場を観察する。
- 委託先の管理責任者にインタビューする。
- 委託先に「委託先情報セキュリティ対策状況確認リスト」を送付し、実施状況について回答してもらう。

第3項 再委託

当社が委託する業務を、委託先が他の組織又は個人に再委託する場合には、事前に書面による報告を委託先に求める。報告には必要に応じて以下の提供を含め、当社の「前々項 委託契約の締結」「前項 委託先の評価」と同等の管理を再委託先に求めていることを確認し、情報セキュリティ責任者及びIT管理者の承認を得たうえで再委託を認める。

- ・委託先と再委託先との契約書案の写し（情報セキュリティに関連する部分のみ）
- ・再委託先の選定基準
- ・再委託先が情報セキュリティに関する適合性評価制度の認証・認定を取得している場合にはその証書の写し

10-1 業務委託契約に係る機密保持条項

第1条（機密保持）

1. 中星工業株式会社（甲）及び_____（乙）は、本契約の履行に当たり、甲が機密である旨指定して開示する情報及び本契約の履行により生じる情報（以下「機密情報」という）を機密として取り扱い、甲の事前の書面による承諾なく第三者に開示してはならない。ただし、次の各号のいずれかに該当する情報については、この限りではない。

- ①開示を受けたときに既に公知であったもの
- ②開示を受けたときに既に自ら所有していたもの
- ③開示を受けた後に自らの責によらない事由により公知となったもの
- ④開示を受けた後に第三者から守秘義務を負うことなく適法に取得したもの
- ⑤開示の前後を問わず自らが独自に開発したことを証明し得るもの

2. 乙は、甲より開示された機密情報の管理につき、自ら保有する他の情報、物品等と明確に区別して管理するとともに、以下の事項を遵守する。

(1) 機密情報の管理責任者及び保管場所を定め、善良なる管理責任者の注意をもって保管管理する。管理責任者及び保管場所に特に指定がない場合、管理責任者として社長又は公に会社の代表とする者とし、保管場所は本社所在地又は当初の取り決めによる場所と見なす。

(2) 機密情報を取り扱う従業員を必要最小限にとどめ、上記保管場所以外へ持ち出さない。

(3) 乙は機密情報の管理責任者名、機密情報を取り扱う従業員名及び機密情報に関する情報セキュリティ対策を、○年○月○日までに書面、メール等証拠が残る方法にて甲に報告する。また、報告内容に変更が生じた場合には、速やかに当該変更内容を相手方に報告する。

(4) (3)にて報告した機密情報を取り扱う従業員に対して本契約の内容を周知徹底させ、機密情報の漏洩、紛失、破壊、改ざん等を未然に防止するための措置を取る。

(5) 乙は甲の書面による承諾を得た場合を除き、機密情報を複写、複製せず、また、機密情報を開示、漏洩しない。但し、政府機関又は裁判所の命令により要求された場合、その範囲で開示することが出来る。なお、その場合には、甲にその旨を速やかに通知すること。

(6) 機密情報は本契約の目的の範囲でのみ使用する。

(7) 乙は事故発生時には直ちに甲に対して通知し、事故復旧対策並びに事故再発防止策の協議には甲の参加を認める。

(8) 委託期間満了時又は本契約の解除時、機密情報（(5)に基づく複写、複製を含む）を甲に返却、又は自己で廃棄の上廃棄の証拠を甲に報告する。

(9) (8)にかかわらず、甲から返却また廃棄を求められたときは、機密情報（(5)に基づく複写、複製を含む）を甲に返却、又は自己で廃棄の上廃棄の証拠を甲に報告する。

(10) 甲は、乙に対して、機密情報の以下の具体的管理状況に関する報告を求めることができる。この報告結果をもとに、甲が乙の事務所における機密情報の管理状況を確認するために乙の事務所への立入検査を希望する場合には、当該検査に協力する。また、甲は乙に対して是正措置を求めることができ、乙はこれを実施するものとする。

①委託契約範囲外の加工、利用の禁止の遵守

②委託契約範囲外の複写、複製の禁止の遵守

③情報セキュリティ対策状況

第2条（再委託）

1. 乙は、本業務（の全部、又は一部）を第三者へ再委託する場合、甲の事前の書面による同意を得ずに、再委託してはならない。

2. 前項の規定に基づき本業務を再委託する場合、乙は自己が負う義務と同等の義務を再委託先に対して書面にて課すとともに、甲に対して再委託先に当該義務を課した旨を書面により報告し、かつ乙は当該機密情報開示に伴う全責任を負うものとする。また、乙は次項第3号の再委託先からの報告を、第1条（機密保持）第3項の具体的管理状況の報告時にあわせて甲に報告する。

3. 前項に加え、乙は再委託先から次の各号の同意を得なければならない。また、乙は、当該同意を得た旨を甲に書面で報告する。

①事故発生時には直ちに甲に対しても通知すること

②事故復旧対策並びに事故再発防止策を協議する際は甲が希望する場合参加を認めること

③再委託先における機密情報の具体的管理状況の報告は、甲の閲覧も可とすること

第3条（権利義務の譲渡）

乙は、本契約によって生じる権利又は義務を第三者に譲渡し、又は承継させてはならない。

第4条（納入物件の知的財産権）

1. 納入物件に関する著作権（著作権法第27条及び第28条に定める権利を含む。）、本契約の履行過程で生じた発明（考案及び意匠の創作を含む。）及びノウハウを含む産業財産権（特許その他産業財産権を受ける権利を含む。）（以下「知的財産権」という。）は、乙又は国内外の第三者が従前から保有していた知的財産権を除き、別紙契約書にて定めた請負業務完了の日をもって、乙から甲に自動的に移転するものとする。

2. 納入物件に、乙又は第三者が従前から保有する知的財産権が含まれている場合は、前項に規定する移転の時に、乙は甲に対して非独占的な実施権、使用权、第三者に対する利用許諾権（再利

用許諾権を含む。)、その他一切の利用を許諾したものとみなす。なお、その対価は契約金額に含まれるものとする。

3. 乙は、甲及び甲の許諾を受けた第三者に対し、納入物件に関する著作権人格権、及び納入物件に対する著作権法第 28 条の権利、その他“原作品の著作者／権利者”の地位に基づく権利主張は行わないものとする。

第 5 条（知的財産権の紛争解決）

1. 乙は、納入物件に関し、甲及び国内外の第三者が保有する知的財産権（公告、公開中のものを含む。）を侵害しないことを保証するとともに、侵害の恐れがある場合、又は甲からその恐れがある旨の通知を受けた場合には、当該知的財産権に関し、甲の要求する事項及びその他の必要な事項について調査を行い、これを甲に報告しなければならない。

2. 乙は、前項の知的財産権に関して権利侵害の紛争が生じた場合（私的交渉、仲裁を含み、法的訴訟に限らない。）、その費用と責任負担において、その紛争を処理解決するものとし、甲に対し一切の負担及び損害を被らせないものとする。

第 6 条（損害賠償）

乙は、乙の責に帰すべき事由によって甲又は第三者に損害を与えたときは、その被った通常かつ直接の損害を賠償するものとする。ただし、乙の負う賠償額は、乙に故意又は重大な過失がある場合を除き、対象案件に関連する契約にて定められた契約金額の合計を超えないものとする。

第 7 条（協議）

本契約に定める事項又は本契約に定めのない事項について生じた疑義については、甲乙協議し、誠意をもって解決する。

第 8 条（その他）

本業務委託契約完了後 3 年間は本契約内容を有効とする。また、本業務委託契約にて各項にて定義された「権利義務の譲渡」「成果の帰属」「損害賠償」「法令等の遵守義務」「協議事項」「紛争の解決」については本業務委託契約完了後であっても 10 年間有効とする。

本業務委託契約に関する紛争については、甲府地方裁判所を唯一の合意管轄裁判所とする。

10-2 委託先情報セキュリティ対策状況確認リスト

会社名：

確認者：

確認日：

区分	No	確認項目	実施状況 (○、×)
社内体制	1	情報セキュリティ管理責任者を定めている	
	2	情報セキュリティ対策を定めた規程を整備している	
	3	情報セキュリティへの取り組み方針を従業員や取引先に周知している	
	4	情報セキュリティ事故に対する対応手順を整備している	
	5	定期的に情報セキュリティに関する内部点検を実施している	
人的管理	6	情報セキュリティに関する教育を定期的の実施し、受講記録を作成している	
	7	従業員と守秘義務契約を交わしている	
物理的管理	8	関係者以外の事務所への立ち入りを制限している	
	9	機密情報の保管について施錠管理をしている	
	10	機密情報を保管している領域に入ることができる人を制限し、入退出記録を取得している	
	11	入退出記録を定期的に確認している	
情報機器・ 媒体の取り扱い	12	機器・媒体の盗難防止措置を講じている	
	13	媒体の無断複製、不正持出しを防止する措置を講じている	
	14	媒体の移送、受け渡し時の保護措置を講じている	
	15	媒体の安全な消去、廃棄の手順を整備している	
技術的対策	16	業務で使用するサーバー・パソコンのウイルス対策を行っている	
	17	業務で使用するサーバー・パソコンは利用者認証機能を設定している	
	18	業務で使用するサーバー・パソコンに利用制限等を設け管理している	
再委託先 管理	19	重要情報の授受を伴う委託先との契約書には、秘密保持条項を規定している	
	20	重要情報の授受を伴う委託先には自社と同等の情報セキュリティ対策を求めている	

第 5 章 事業継続
第 1 節 インシデント対応

第 11 条 （情報セキュリティインシデント対応ならびに事業継続管理）

第 1 項 対応体制

情報セキュリティインシデントが発生した場合には、以下の体制で対応する。

最高責任者	代表取締役
対応責任者	インシデント対応責任者
一次対応者	発見者、IT 管理者又は情報システム管理者

第 2 項 情報セキュリティインシデントの影響範囲と対応者

情報セキュリティインシデントが発生した場合、以下を参考に影響範囲を判断して対応する。

事故レベル	影響範囲	責任者
3	・顧客、取引先、株主等に影響が及ぶとき ・個人情報情報が漏えいしたとき	代表取締役
2	事業に影響が及ぶとき	インシデント対応責任者
1	従業員の業務遂行に影響が及ぶとき	インシデント対応責任者
0	インシデントにまでは至らないが、将来においてインシデントが発生する可能性がある事象が発見されたとき	IT 管理者又は情報システム管理者

第 3 項 インシデントの連絡及び報告

レベル 1 以上のインシデントが発生した場合、発見者は以下の連絡網に従い、対応者または責任者に速やかに報告し、指示を仰ぐ。

対応者または責任者	緊急連絡先
代表取締役	携帯電話：080-2221-8015 電子メールアドレス：kondo@nakaboshi.co.jp
インシデント対応責任者	携帯電話：090-2113-4238 電子メールアドレス：toyama@nakaboshi.co.jp
情報システム管理者	携帯電話：090-2113-4238 電子メールアドレス：toyama@nakaboshi.co.jp

第 4 項 対応手順

インシデントを以下のとおりに区分し、それぞれの対応手順を示す。

区分	事件・事故の状況
漏えい・流出	社外秘又は極秘情報資産の盗難、流出、紛失

改ざん・消失・破壊 サービス停止	情報資産の意図しない改ざん、消失、破壊 情報資産が必要なときに利用できない
ウイルス感染	悪意のあるソフトウェアに感染

1. 漏えい・流出発生時の対応

事故レベル	対応手順
3	①発見者は即座にインシデント対応責任者及び代表取締役社長に報告する。 ②インシデント対応責任者は自身の責において情報システム管理者並びに IT 管理者と共に原因を特定し、二次被害が想定される場合には防止策を実行する。 ③インシデント対応責任者は被害者/本人対応を準備する。 ④インシデント対応責任者は問い合わせ対応を準備する。 ⑤インシデント対応責任者は影響範囲・被害の大きさによっては総務部に報道発表の準備を申請する。 ⑥インシデント対応責任者はサイバー攻撃等の不正アクセスによる被害の場合は都道府県警察本部のサイバー犯罪相談窓口届け出る。 ⑦インシデント対応責任者は個人データまたは特定個人情報漏えいの場合には個人情報保護委員会に報告する。 ⑧代表取締役は社内及び影響範囲の全ての組織・人に対応結果及び対策を公表する。 個人データ：個人情報データベース等（特定の個人を検索できるようにまとめたもの）を構成する個人情報
2	①発見者は発見次第、情報システム管理者に報告する。 ②情報システム管理者は漏えい先を調査し、インシデント対応責任者に報告する。 ③情報システム管理者は社内関係者に周知する。
1	※情報漏えい・流出は全て事故レベル 2 以上

2. 改ざん・消失・破壊・サービス停止発生時の対応

事故レベル	対応手順
3	①発見者は即座にインシデント対応責任者及び代表取締役社長に報告する。 ②情報システム管理者は原因を特定し、IT管理者に応急処置を指示する。 ③インシデント対応責任者は社内に周知するとともにIT管理者に連絡する。 ④機器の場合はIT管理者が修理、復旧、交換等の手続きを行う。 ⑤書類・フィルム原本の場合は情報セキュリティ部門責任者が可能な範囲で修復する。 ⑥情報システム管理者は原因対策を実施する。

	代表取締役は社内及び影響範囲の全ての組織・人に対応結果及び対策を公表する。
2	①発見者は発見次第、IT管理者又は情報システム管理者に報告する。 ②情報システム管理者はIT管理者に原因を特定し、応急処置を指示する。 ③インシデント対応責任者は社内に周知するとともにIT管理者に連絡する。 ④機器の場合はIT管理者が修理、復旧、交換等の手続きを行う。 ⑤書類・フィルム原本の場合は情報セキュリティ部門責任者が可能な範囲で修復する。 ⑥IT管理者は原因対策を実施する。
1	①情報システム管理者はIT管理者に原因特定及び、応急処置を指示する。 ②機器の場合はIT管理者が修理、復旧、交換等の手続きを行う。 ③書類・フィルム等の原本の場合は情報セキュリティ部門責任者が可能な範囲で修復する ④IT管理者は原因対策を実施する
0	発見者は発見次第、発生可能性のあるインシデントと想定される被害をIT管理者又は情報システム管理者に報告する。

3. ウイルス感染時の初期対応

従業員は、業務に利用しているパソコン、サーバー又はスマートフォン、タブレット（以下「コンピュータ」といいます。）がウイルスに感染した場合には、以下を実行する。

- ①ネットワークからコンピュータを切断する。
- ②IT 管理者又は情報システム管理者に連絡する。
- ③ウイルス対策ソフトを実行しウイルス名を確認する。
- ④ウイルス対策ソフトで駆除可能な場合は駆除する。
- ⑤駆除後再度ウイルス対策ソフトでスキャンし、駆除を確認する。
- ⑥IT 管理者又は情報システム管理者に報告する。

以下の場合など従業員自身で対応できないと判断される場合は IT 管理者に問い合わせる。

- ・ウイルス対策ソフトで駆除できない。
- ・システムファイルが破壊・改ざんされている。
- ・ファイルが改ざん・暗号化・削除されている。

4. 届出及び相談

情報システム管理者は、インシデント対応後に以下の機関への届け出、報告又は相談を検討する。

<届出・相談・報告先>

【独立行政法人 情報処理推進機構セキュリティセンター (IPA/ISEC)】

➤ ウイルスの届出

<https://www.ipa.go.jp/security/outline/todokede-j.html>

TEL: 03-5978-7518

E-mail: virus@ipa.go.jp

➤ 不正アクセスに関する届出

E-mail: crack@ipa.go.jp

FAX: 03-5978-7518

➤ 情報セキュリティ安心相談窓口

<https://www.ipa.go.jp/security/anshin/index.html>

TEL: 03-5978-7509

E-mail: anshin@ipa.go.jp

【個人情報保護委員会】

➤ 個人データの漏えい等の事案が発生した場合等の対応

①個人データ（特定個人情報に係るものを除く。）の漏えい、滅失又は毀損

②加工方法等情報（匿名加工情報の加工の方法に関する情報等）の漏えい

③上記①又は②のおそれ

漏えい等事案が発覚した場合は、速やかに下記 UR を参照して個人情報保護委員会等に対し、報告すること

<https://www.ppc.go.jp/personalinfo/legal/leakAction/>

TEL: 03-6457-9685

個人情報保護委員会事務局 個人データ漏えい等報告窓口

➤ 特定個人情報の漏えい事案が発生した場合の対応

①番号法違反又は違反のおそれ

番号法違反又は違反のおそれを把握した場合は、速やかに下記 UR を参照して個人情報保護委員会等に対し、報告すること

<https://www.ppc.go.jp/legal/rouei/>

②重大事態に該当する事案又はそのおそれ

《重大事態》

- 情報提供ネットワークシステム等又は個人番号利用事務を処理するために使用する情報システムで管理される特定個人情報が漏えい等した事態
- 漏えい等した特定個人情報に係る本人の数が 100 人を超える事態
- 特定個人情報を電磁的方法により不特定多数の者が閲覧することができる状態となり、かつ閲覧された事態
- 従業員等が不正の目的をもって、特定個人情報を利用し、又は提供した事態

重大事態が発覚した場合は、直ちに下記 URL を参照して個人情報保護委員会等に対し、報告すること

<https://www.ppc.go.jp/legal/rouei/>

個人情報保護委員会事務局 特定個人情報漏えい等報告窓口

TEL:03-6457-9680

第5項 情報セキュリティインシデントによる事業中断と事業継続管理

代表取締役は、情報セキュリティインシデントの影響により当社事業が中断した場合に備え、以下を定める。

1. 想定される情報セキュリティインシデント

以下のインシデントによる事業の中断を想定する。

- ・情報セキュリティインシデント：大型地震の発生に伴う設備の倒壊、回線の途絶、停電等による見積から出荷までを管理する各業務システムの停止
- ・想定理由：当社の事業は、見積から出荷までを管理する各業務システムに依存しているため、停止した場合は事業の継続が困難になり多大な損失が発生

2. 復旧責任者及び関連連絡先

被害対象	復旧責任者	関係者連絡先
電源設備 空調機	総務部長	株式会社双葉電気 甲信日成株式会社
ファイルサーバー ネットワーク機器 回線サービス	インシデント対応責任者 情報システム管理者	株式会社シップス NTT ドコモビジネスソリューションズ
顧客	営業部長	営業部取引先リスト参照
従業員人的被害	総務部長	従業員名簿参照

3. 事業継続計画

インシデント対応責任者は、想定する情報セキュリティインシデントが発生し、事業が中断した際の復旧責任者の役割認識及び関係者連絡先について、有効に機能するか検証する。復旧責任者は、被害対象に応じて復旧から事業再開までの計画を立案する。

4. EUC(End User Computing)による事業継続リスク

情報セキュリティ部門責任者は部門内で EUC によるツール開発した社員の異動、退職による事業継続リスクを考慮する。考慮する具体的内容は第4章第1節第9条第5項 EUC(End User Computing)の制限に準ずる。

附則

この規程は、令和 7 年 10 月 1 日から施行する。